DOCUMENT

09

Code Review Report

Every review finding and its verdict

Summary

Ports the demo app's backend from ASP.NET Core to Python/FastAPI (behaviour-identical, 7 original tests kept), then adds approval limits by role: Manager up to 50,000, Director up to 500,000, and two distinct approvers (second a Director) above that. A refused approval returns a clear reason (HTTP 403) and changes nothing.

Also in this PR: extended `AGENTS.md`, Spec Kit specification under `specs/001-invoice-approval-limits/`, project skills/agents/hooks under `.claude/`, one Playwright e2e test, mutation-testing scripts, and the AI interaction log.

Evidence

```
python -m pytest backend/tests -q        -> 177 passed
mutmut (domain package)                  -> before 63.9% (23/36 killed), after 100.0% (86/86
killed)
cd e2e && npm test                       -> 1 passed (manager refused on 75,000.00 invoice,
invoice unchanged)
```

AI review of this diff

The diff was reviewed by the `pr-reviewer` role (`.claude/agents/pr-reviewer.md`, output format `.claude/skills/review-findings`). It returned 11 findings; each has exactly one verdict. The reviewer reproduced F1 and F2 against the running code before reporting them.

id	severity	location (at review time)	finding	verdict	reason / fix
F1	high	`domain/approval_service.py:36`	`approve()` check-then-record is not atomic; two simultaneous approvals by the same Director both pass the "already approved" check, giving an Approved invoice with two approvals from one user.	**fixed**	`ApprovalService` now holds a lock around `submit` / `approve` / `reject`. New tests use a database-like `SnapshotRepository` (snapshot reads, delayed saves) and run two threads: exactly one `ok` + one `refused` for the same user, both `ok` for two different Directors. Verified the tests fail (2 failed) with the lock replaced by a no-op and pass with it. Also an HTTP-level 4-click test.

id	severity	location (at review time)	finding	verdict	reason / fix
F2	high	`api/routers/invoices.py:57`	Amount only checked `> 0`: `1e999999` is stored, then `float()` serialization fails and breaks `GET /api/invoices` for everyone until restart.	**fixed**	Request model now `Field(gt=0, max_digits=14, decimal_places=2)`; invalid amounts return 400 with a specific message and are never stored. Parametrized test covers `1e999999`, `NaN`, `Infinity`, sub-cent, negative, zero, too many digits, and asserts the list endpoint still works and is unchanged.
F3	medium	`api/routers/invoices.py:54`	Sub-cent amounts (`50000.001`) accepted, so the "refused: invoice is 50,000.00" message contradicts the actual amount.	**fixed**	Same validation as F2 (`decimal_places=2`).
F4	medium	`api/serialization.py:10`	`float(amount)` loses precision for huge values and can overflow.	**dismissed**	The unbounded-input cause is fixed under F2: amounts are at most 12 integer digits + 2 decimals, which a double represents exactly to the cent. `test_amounts_at_the_limits_round_trip_exactly` proves 50,000.00 / .01, 500,000.00 / .01 and 999,999,999,999.99 survive the JSON round trip. Switching the wire format to strings would change the UI contract for no remaining benefit.
F5	medium	`api/main.py:23`	Every `ValueError` maps to 400 and echoes `str(error)`, so unexpected errors look like client errors and leak internals.	**fixed**	New `DomainValidationError(ValueError)`; only it maps to 400. Unexpected exceptions are now 500 without detail. Existing `pytest.raises(ValueError)` tests still hold because it subclasses `ValueError`; tests now assert the new type and exact message.

id	severity	location (at review time)	finding	verdict	reason / fix
F6	medium	`api/in_memory_repository.py:50`	`update()` silently does nothing for a missing invoice (approve could return 200 for a deleted invoice); `get_by_id` returns the live object.	**fixed**	`update()` now raises `InvoiceNotFoundError` (the test fake matches). The live-object aliasing is covered by check-before-mutate plus the service lock for all service paths; returning copies is not needed while the repository is in memory.
F7	medium	`e2e/tests/over-limit-rejection.spec.ts:6`	No e2e for the "1 of 2 approvals" progress or the two-Director UI flow; `reuseExistingServer: true` makes state depend on a running server.	**deferred**	The assignment asks for one e2e on the rejected over-limit approval, and the existing test is idempotent (a refusal changes nothing), so a reused server does not break it. The two-Director flow and progress data (`requiredApprovals`, `approvals`) are covered at API level. Tracked as follow-up T024: add a second spec with a reset endpoint so mutating UI tests are repeatable.
F8	medium	`backend/tests/test_api.py:137`	No concurrency/idempotency test, and API refusal tests did not assert the approvals array.	**fixed**	Added the threaded tests from F1, an HTTP double-click test (4 simultaneous clicks -> one 200, three 403), and refusal tests that compare the full invoice (including `approvals`) before and after.
F9	low	`domain/approval_policy.py:49`	Role strings are matched exactly (`director` or `Director` would be refused).	**dismissed**	Roles come only from the server-side user table, never from user input, and failing closed is the safe default. `test_role_names_are_matched_exactly_so_a_mistyped_role_fails_closed` pins the behaviour so it is a decision, not an accident.
F10	low	`api/routers/invoices.py:67`	Create/submit open to every role; router role list and domain role list could drift.	**dismissed**	Create/submit were open to every signed-in user in the original app and the feature does not change that (AGENTS.md restricts only destructive actions). The router list deliberately includes Admin (who may reject) and differs from the approver roles; the domain remains the single authority on who may approve.

id	severity	location (at review time)	finding	verdict	reason / fix
F11	low	`api/auth/session_store.py:20`	Tokens never expire; password compare is not constant-time; no throttling.	**deferred**	Pre-existing demo authentication (local, in-memory, documented as non-production), outside this feature. Tracked as follow-up T025: expiry + `hmac.compare_digest`.

Test review (separate pass by the `test-reviewer` role)

14 gaps were reported against the first test suite. All were acted on or consciously declined:

- STRENGTHEN (state-error tests checked only the exception type; reject-without-reason did not prove nothing changed; the fake hid "forgot to save"): fixed. State and not-found errors now assert exact message, unchanged invoice and `repository.updated == []`, for submit, approve and reject across every wrong status.
- REMOVE (2 duplicate tests): removed.
- Missing tests 1-10, 12, 13: added (manager-then-manager above the limit, stored-side case/whitespace, 500,000.01 through the service, 50,000.01 by a Director, state-before-permission ordering, role strictness, API 401s and Admin refusal).
- Item 11 (non-positive amounts in the policy): declined at policy level; amounts are validated at the API boundary (F2) and the policy is a pure function of a valid invoice.
- Item 14 (fake `update` ignoring unknown ids): fixed, the fake now raises like the real repository.

Not done in this PR

- Tasks T024 and T025 above (deferred findings).
- Demo video (recorded separately; link in `ASSIGNMENT.md`).